

Információ biztonság

- Alapfogalmak
- Mit jelent az, hogy információ?
- Milyen adatot kell védeni?
- Mi az információ biztonság?
- Kik a támadók?
- Milyen támadásokra számíthatunk?

Mi az információ?

Általános értelemben információ minden olyan jel, szimbólum vagy jelzés, amellyel az ember képes már emberre hatni oly módon, hogy ettől annak viselkedése megváltozzék. Az információt kibocsátó az adó, az azt befogadó a vevő, maga az információ, mint üzenet valamilyen információtovábbító csatornán át jut a befogadóhoz. Szűkebb meghatározása: számunkra új ismereteket hordozó jelek tartalmi jelentése. Funkcionális szempontból lényeges tulajdonsága, hogy mindig csökkenti a bizonytalanságot.

Tömören: Az információ adatok olyan rendezett és értelmezett halmaza, amely új ismeretet közvetít, csökkenti a bizonytalanságot, vagy segíti a döntéshozatalt.

Az információ feldolgozása több módszerrel történhet.

Az információ kulcsszerepű.

Beszélhetünk fizikális (papír alapú, grafikus információk, szöveg alapú információk (dokumentum)) és elektronikus információról (kép (.png, .jpg, stb.), hang, videó, dokumentum, forráskód).

Mi is az információvédelem?

- Az információ bizalmasságának, sértetlenségének és rendelkezésre állásának biztosítása.
- CIA

Mit és miért is védünk?

- Bizalmas adatok (érték mások számára), pl. személyi adatok, bankszámla adatok, cégi adatok
 - anyagi
 - személyes
 - politikai célok

Támadók

- más államok - állami **titkok** megszerzése
- szervezett bűnözés - elsődleges cél a **pénz**
- tüntetők - **figyelmet** szeretnének
- hackerek és kutatók - céljuk a **tudás** és nagyobb rálátás megszerzése

Mit tehet a támadó?

- Eaversdrop (hallgatóság) – routerek, linkek, szolgáltatások
- Önkényes üzenetek küldése
- Felvett üzenetek visszajátzása
- Üzenetek megváltoztatása (fejrész/tartalom)
- Rosszindulatú kódok futtatása/erre trükkel rávezetni embereket
- Bug kihasználása és „vezérlés átvétele” az eszköz felett

Milyen eseményektől kell tartanunk?

- személyazonosság ellopása, az azzal való visszaélés
- adatok vagy eszközök ellopása - illetéktelen hozzáférés
 - személyes adatok, bankszámlák, szerződések
- kémkedés
 - titkos adatok konkurenciához való kerülése
- **kiberháború**
 - nem feltétlenül jelent közvetlen fizikai pusztítást, de gazdasági, politikai és akár katonai következményei lehetnek

Az információbiztonság alapelvei

- CIA
 - TRV
 - AAA
-
- AAA
 - RBAC
 - ABAC
 - MAC - kötelező hozzáférés-ellenőrzés (mandatory access control)
 - DAC - diszkrecionális hozzáférés-kezelés (discretionary access control)
 - RBAC - szabályalapú hozzáférés-vezérlés (rule-based access control)
-
- TRV
 - Fenyegetés (Threads)
 - Sebezhetőség (Vulnerability)
 - Kockázat (Risk) (magas, közepes, alacsony)
 - Szoftverhibák (bug) – konfigurációs hibák, hálózattervezés hibák, titkosítási hiányosságok

KOCKÁZATI KATEGÓRIÁK

KATEGÓRIA	JELLEMZŐK	KOCKÁZATI SZINT	BIZTONSÁGI INTÉZKEDÉSEK
Alacsony	Nyilvános vagy kevésbé érzékeny információk	Minimális	Alapszintű védelem (pl. jelszavas védelem, tűzfal)
Közepes	Üzleti vagy személyes adatok	Mérsékelt	Titkosítás, hozzáférés-korlátozás, naplózás
Magas	Kritikus vagy titkos információk	Nagyon magas	Többszintű védelem, erős titkosítás, szigorú hozzáférés-kezelés

Kriptográfia: az a tudományág, amely a titkosítás matematikai és algoritmikus hátterét biztosítja.

Klasszikus titkosítási módszerek

- Fisher-Yates keverés: véletlenszerű permutációs algoritmus (inkább randomizálási eljárás)
- Caesar-rejtjel: egyszerű szimmetrikus titkosítási módszer
- Vigenére titkosítás: több eltérő Caesar-elmozdítást használ egy ismétlődő kulcsszó alapján

Fisher-Yates keverés

Egy hatékony és igazságos algoritmus, amelyet egy lista elemeinek véletlenszerű összekeverésére használnak.

Az algoritmus biztosítja, hogy minden lehetséges permutáció azonos valószínűséggel forduljon elő.

Az eredeti Fisher-Yates keverés lépései:

1. Indulunk a lista utolsó elemétől (index $n-1$).
2. Minden elemhez (index i) véletlenszerűen kiválasztunk egy j indexet az $[0, i]$ tartományból.
3. Felcseréljük az i -edik és j -edik elemet.
4. Ezt ismétljük az első elemig (index 1).

Nincs titkosítási kulcs: A Fisher-Yates keverés nem használ semmilyen kulcsot vagy titkosítási műveletet.

Nem reverzibilis: egy titkosítási algoritmusnál vissza kell tudnunk fejtetni az eredeti adatokat, de a Fisher-Yates keverésnél nem lehet az eredeti sorrendet visszaállítani, ha nem jegyezzük fel az eredeti állapotot.

Nem véd adatokat: az algoritmus célja a véletlenszerűség (?)

Brute force: nyers erő, egy olyan módszer az algoritmusok és a kiberbiztonság területén, amely minden lehetséges lehetőséget kipróbál a megoldás megtalálásához. Nem optimalizál, hanem az összes lehetőséget végignézi, amíg meg nem találja a megfelelőt. Hatékonysága alacsony, mert exponenciális időbonyolultságú lehet, de mindig működik, ha elég erőforrás áll rendelkezésre. Ez egy módszer jelszavak, titkos kulcsok vagy titkosított adatok feltörésére azáltal, hogy minden lehetséges kombinációt kipróbálunk.

Caesar titkosítás

Egy elcsúsztatásos titkosítás, ahol minden betűt egy előre meghatározott számú helyen az abc-ben.

Titkosítás: $C = (P + k) \bmod 26$

C = titkosított karakter

P = eredeti karakter pozíciója

k = a kulcs (eltolás)

$\bmod 26$ = biztosítja a körforgást (ha elérjük a Z-t, utána az A jöjjön)

Dekódolás: $P = (C - k) \bmod 26$

P = az eredeti (de titkosított) karakter pozíciója

C = a titkosított karakter pozíciója

k = az eltolás (kulcs)

$\bmod 26$ = biztosítja a visszafejtésnél is az abc ciklikusságát (körforgását)

Pro:

- Egyszerű és gyors alkalmazni.
- Könnyen megvalósítható, akár gépi algoritmus nélkülözésével is.

Kontra:

- Könnyen fel lehet törni, mivel csak 26 lehetséges kulcs létezik (angol abc).
- A brute force támadók egyszerűen minden kulccsal kipróbálhatják az összes lehetséges szöveget, amíg meg nem találják a megfelelőt.

Vigenére-felé titkosítás

Ez egy helyettesítő típusú titkosítási eljárás, amely a Caesar-titkosítást egy bonyolultabb, több kulcsot használó változatként fejleszti tovább. Egy szimmetrikus kulcsú titkosítást alkalmaz, ahol a kulcs ismétlődő szekvenciáját használjuk az üzenet titkosításához.

Bemeneti szöveg: az üzenet, amit titkosítani szeretnénk

Kulcs: egy kulcs, amit az üzenethez igazítunk. A kulcs ismétlődik az üzenet hosszában.

Titkosítási képlet: a titkosítás minden karaktere az üzenetből egy szám (pozíció) alapján történik, és a kulcs karakterek segítségével történik a helyettesítés:

$$C_i = (P_i + K_i) \bmod 26$$

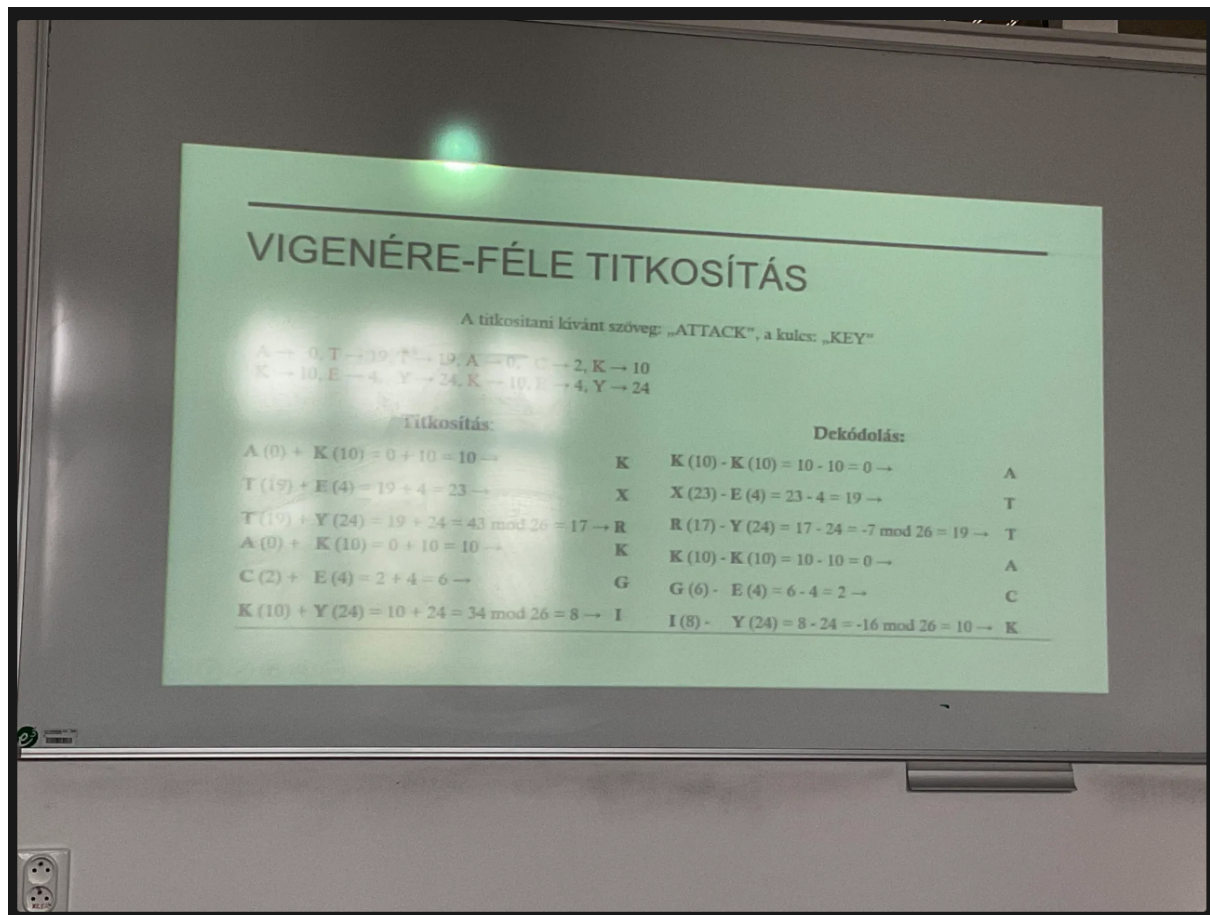
P_i = az üzenet i-edik karakterének pozíciója az abc-ben

K_i = a kulcs i-edik karakterének pozíciója az abc-ben

C_i = ?

Dekódolás:

$$P_i = (C_i - K_i) \bmod 26$$



Kontra: frekvencia elemzés

- Jelszavak
 - Karakterek karakterlánca, amelyet a személyazonosság hitelesítésére vagy a hozzáférési jogosultság ellenőrzésére használnak.
 - A jelszó vagy más néven kulcsszó, kódszó, kód vagy jelmondat, egy jeltől vagy jelsorból álló kifejezés, melyet azonosításhoz, ill. hitelesítéshez használunk. Célja, hogy egy egyedi azonosítóval felcserélhetetlenül megerősíthessük kilétünket.
- Jelszó irányelv
 - Olyan szabályok halmaza, amelyek a jelszavak használatának és adminisztrálásának módját szabályozzák. Ezek a szabályok annak biztosítása érdekében kerültek kialakításra, hogy a felhasználók a jelszavakat rendszeres időközönként cseréljék.
 - A jelszó erősség szabály olyan szabály, amelynek a jelszónak meg kell felelnie (pl. minimális hossz, ill. az engedélyezett és nem engedélyezett különböző típusú karakterek száma).
- IBM szabvány szerint:
 - 15 karakter hossz, nagy és kis betűk, numerikus, spec. karakterek

- Microsoft szabvány szerint:
 - 12 karakter hosszú, de 14 vagy több a jobb, nagy és kis betűk, számok, szimbólumok kombinációja. A szótárban nem található szó, sem személy, karakter, termék vagy szervezet neve. Jelentősen eltér a korábbi jelszavaktól.
- Kriptográfiai hash-függvények:
 - Olyan matematikai algoritmusok, amelyek egy tetszőleges hosszúságú bemenetet fix hosszúságú, egyedi kimenetű alakítanak. Ezeket a kimeneteket nevezzük hash értéknek vagy kivonatnak. A hash függvényeknek az információbiztonságban kiemelt szerepük van, mert biztosítják az adatok integritását, hitelességét és biztonságát.
 - Tulajdonságai:
 - Deterministicitás: ugyanazon bemenet mindig ugyanazt a hash értéket adja
 - Gyors számítás: a hash érték kiszámítása hatékonyan elvégezhető
 - Ütközésállóság: Két különböző bemenet esetén nagyon nehéz ugyanazt a hash értéket előállítani.
 - Előképképtelenség: A hash értékből nem lehet visszafejteni az eredeti adatot.
 - Avalanche-effektus: Ha a bemenetben egyetlen bitet megváltoztatunk, a hash érték jelentősen megváltozik.
 - Hash algoritmusok:
 - MD2 - elavult, nem biztonságos
 - SHA-1 - már nem ajánlott
 - SHA-256 - biztonságos, gyakran használják, SH
 - SHA-3 - legújabb szabvány
- SHA 256 - működése (???)
 - "üzenet" - bináris (24 bit)
 - padding - 512 bitre bővítés
 - alap SHA-256 hash állapot inicializálása
 - 64 lépéses keverés (XOR, AND, ROT, SHIFT, stb.)
 - végső hash érték előállítása (256 bit, hex formátumban)

7.) óra anyaga

- SHA-256
- Vírusok, víruscsoportok, Malwarek (?)
- A rosszindulatú szoftverek (malware - malicious software) olyan programok vagy kódok, amelyeket arra terveztek, hogy kárt okozzanak számítógépes rendszerekben, hálózatokban és felhasználók adataiban. Ezek a szoftverek különböző módokon működhetnek, leggyakrabban: adatokat lohatnak, rendszereket károsíthatnak, átvehetik az irányítást egy eszköz felett.
- Malware típusok: különböző típusok különböző tulajdonságokkal rendelkeznek és platformokon (Windows, Linux, UNIX, Android, iOS, stb.) fordulnak elő.
 - Vírusok, férgek, logikai bombák, trójai falovak, baktériumok, exploit vírusok, letöltők, tárcsázók, dropperek, injektorok, automatizált jogosultságszerzők, kitek, spammer programok, flooderek, billentyűzetnaplózók, rootkitek, spyware, hirdető programok, zsaroló vírusok, kriptó vírusok, Destructoware

• Vírusok

- A vírusok olyan rosszindulatú programok, amelyek más fájlokhoz vagy programokhoz csatolva terjednek. Aktiválódásukhoz szükséges a felhasználó közreműködése (pl. Fertőzött fájl megnyitása). Károkozásuk lehet fájlrendszeri sérülés, adatvesztés vagy rendszerösszeomlás. Jellemzői: más fájlokhoz kapcsolódik; felhasználói interakcióra van szüksége; károkozása változó (adattörlesztés, erőforrás-felhasználás).

• Férgék

- Önállóan terjedő kártékony programok, amelyek hálózatokon vagy más adathordozókon keresztül másolják magukat. Gyakran biztonsági réseket használnak. Jellemzői: automatikusan terjed hálózaton vagy e-mailen keresztül; erőforrásokat használ fel, lassítja a rendszert; lehetőséget biztosíthat további kártevők letöltésére. Morris féreg.

- **Logikai bombák**

- Ezek olyan rosszindulatú programok vagy kódok, amelyek csak egy adott esemény bekövetkezésekor aktiválódnak (pl. Adott időpontban vagy egy bizonyos fájl megnyitásakor). Jellemzői: rejtve marad, amíg a feltétel nem teljesül; kárososá lehet adatok törlése, rendszerleállítás.

- **Trójai falovak**

- Olyan programok, amelyek hasznos alkalmazásnak álcázva jutnak a rendszerbe, de valójában kártékony tevékenységet végeznek. Jellemzői: álcázás alatt áll (pl. játék, segédprogram); hátsó ajtót nyithat támadók számára; nem szaporodik, de súlyos biztonsági kockázatot jelent

- **Baktérium (fork bomba)**

- Az ilyen típusú kártevők nem közvetlenül károsítják az adatokat, hanem önmagukat szaporítva kimerítik a rendszer erőforrásait, pl. memória- vagy processzorhasználatot maximalizálnak. Jellemzői: rendszerleállást vagy túlterhelést okoz; **nem feltétlenül** szándékosan rosszindulatú; egy végtelen ciklushoz hasonlóan működik.

- **Exploit vírus**

- Ezek olyan kártevők, amelyek ismert vagy ismeretlen (zero-day) biztonsági réseket használnak ki, hogy kártékony kódot futtassanak a célrendszeren. Jellemzői: rendszerhibákat vagy szoftveres réseket céloz; gyakran automatikusan terjed; rendszerfrissítések segítenek ellene. Nagyon friss hibákat támadnak meg, amikre még nincs megoldás.

- **Mi is az a zero-day?**

- Olyan biztonsági rés egy szoftverben, amelyet a fejlesztők még nem ismernek, ezért nincs rá javítás; a támadók ezeket a sérülékenységeket kihasználhatják még azelőtt, hogy a hibát kijavítanák.

- **Letöltők**

- Olyan kártevők, amelyek más malware-ek letöltéséért és telepítéséért felelősek. Elsődleges céljuk a további fertőzés lehetővé tétele. Jellemzői: kis méretű, rejtőzködő; internetkapcsolat szükséges a letöltéshez; gyakran része nagyobb támadási láncnak.

- **Tárcsázók**

- Régebben a modemeken internetkapcsolatokat kihasználva emelt díjas telefonszámokat hívtak, ezzel anyagi károkat okozva. Jellemzői: automatikusan tárcsázza az emelt díjas számokat; manapság kevésbé gyakori a szélessávú internet miatt; adathalászat céljára is használható.

- **Dropperek**

- Amelyek más kártékony kódokat csempésznek be a rendszerbe anélkül, hogy azok közvetlenül észlelhetőek lennének. Jellemzői: passzívan elrejt a vírust vagy egyéb kártevőt; gyakran kihasznál fájlrendszeri sebezhetőségeket; kevésbé feltűnő, mint egy letöltő program.

- **Injektorok**

- Amelyek rosszindulatú kódot juttatnak be egy másik folyamatba, így a kártékony kód legitim alkalmazásként futtat. Jellemzői: rendszergazdai jogokat szerezhet; felfedezésre nehéz, mivel meglévő folyamatokat használ; gyakran botnetek részei.

- **Automatizált jogosultságszerzők**

- Ezek a kártékony programok a felhasználói fiókok és jogosultságok megszerzésére specializálódnak, pl. brute-force támadásokkal vagy adathalászzal. Jellemzői: rendszergazdai jogokat szerez; gyakran exploitokat használ; kritikus veszélyforrás céges rendszerekben.

- **Kitek - vírusgenerálók**

- Olyan eszközkészletek, amelyek megkönnyítik a hackerek számára a támadások végrehajtását, pl. exploitokkal vagy automatizált támadómodulokkal. Jellemzői: tartalmazhat trójaiakat, férgeket, exploitokat; felhasználóbarát felület támadóknak; alkalmazásai változatosak (pl. DDoS, adathalászat).

- **Spammer programok**

- Kéretlen reklámokat vagy phishing e-maileket küldenek nagy mennyiségben. Jellemzői: e-mail fiúkokat használ spamküldésre; lehetőségeket teremt adathalászatra; fekete listára kerülhet miatta egy szerver.

- **Flooderek**

- Egy célpontot túlterhelve (pl. DDoS támadással) működésképtelenné tesznek egy rendszert vagy hálózatot. Jellemzői: automatikusan generál nagy mennyiségű forgalmat; leállíthat weboldalakat vagy szolgáltatásokat; botnetekkel kombinálva rendkívül pusztító.

- **Keylogger - billentyűzetnaplózók**

- A billentyűleütéseket rögzítik, hogy bizalmas információkat (pl. jelszavakat) szerezzenek meg. Jellemzői: rejtve fut a háttérben; lehallgathatja bejelentkezéseket, jelszavakat; gyakran trójai programokkal terjed.

- **Rootkitek**

- Mélyen beépülnek a rendszerbe, hogy elrejtse a malware-ek jelenlétét. Jellemzői: rendszermaghoz (kernel) fér hozzá; nehéz észlelni és elvátolítani; kritikus veszélyforrás szervereken.

- **Spyware**

- Adatokat gyűjtenek a felhasználóról és továbbítják azokat. Jellemzői: gyakran reklámprogramokkal együtt érkeznek; adatvédelmi szempontból veszélyes; böngészési szokásokat vagy jelszavakat lophat.

- **Hirdetőprogramok**

- Kéretlen reklámokat jelenítenek meg. Jellemzői: legtöbbször nem kifejezetten rosszindulatú; gyakran freeware alkalmazásokkal terjed; lassíthatja a rendszert.

- **Zsarolóvírus**

- Kártékony szoftver, amely titkosítja az áldozat fájljait, és váltságdíjat követel a visszaállításukért. A támadók általában kriptovalutában kérik a fizetést, hogy ne legyenek könnyen nyomon követhetők.
- Jellemzői:
 - Fájlok titkosítása - a legtöbb esetben erős titkosítási algoritmusokat használ
 - Váltságdíj követelése - a támadók megígérik, hogy fizetés után visszaadják az adatokat (de erre nincs garancia)
 - Sokféle terjedési mód - pl. adathalász e-mailek, exploitok, rosszindulatú hirdetések.

- **Kripto vírusok**

- A zsaroló vírusok egy speciális fajtáját jelentik, amelyek rendkívül erős titkosítást használnak, és szinte lehetetlenné teszik az adatok visszafejtését (amíg a fizetés meg nem történik).
- Jellemzői:
 - Fejlett titkosítás - RSA-2048, AES-256 vagy kombinált hibrid titkosításokat alkalmazhat
 - Kibertámadások részeként alkalmazzák - gyakran nagyvállalatok, kórházak, állami intézmények ellen irányulnak.

- **Destructoware**

- Nem titkosítja az adatokat váltságdíj reményében, hanem véglegesen megsemmisíti azokat. Fő célja a maximális pusztítás.
- Jellemzői:
 - Végleges adattörlés
 - Motivációja gyakran politikai vagy bosszú
 - Nem kér váltságdíjat
- Pl. Shamoon (???)

- **Informatív támadások**

- Humán alapú technikák
- IT alapú technikák
- DoS/DDoS
- XSS
- SQL injection
- Cookie poisoning
- Forráskód, weboldal tükrözés
- Túlsordulás előidézése

8.) óra anyaga

• Humán alapú technikák

- Tailgating = Olyan fizikai biztonsági megsértés, amikor egy illetéktelen személy egy jogosult személy mögött belép egy védett területre, például belépőkártya használata nélkül.
- Piggybacking = Hasonló a tailgatinghez, de itt a jogosult személy tudatában van annak, hogy valaki követi őt, és szándékosan engedi be a másikat is.
- Dumpster diving = Olyan módszer, amikor valaki a szemetesből próbál hasznos információt (pl. kidobott dokumentumokat, jelszavakat, számlákat) szerezni az informatikai rendszerek vagy szervezetek kompromittálása céljából.
- Alapvetően nem szükséges semmilyen technológiai eszköz. Ezekben az esetekben elegendő, ha valakinek az identitását lopják el, és a támadó másnak adva ki magát tud információhoz jutni.
- Ide tartozik még a jelszavak kitalálása (brute force nélkül, csak próbálkozásokkal).

• DOS/DDOS

- Szolgáltatásmegtagadás (DoS) és elosztott szolgáltatásmegtagadás (DDoS).
- a DoS az egy adott gépről induló csomagokat jelenti, míg a DDoS támadást több, általában botnetbe rendeződött eszközök hajtják végre.
- Célja a hálózati forgalom megzavarása.

• Mi az a SYN FLOOD támadás?

- A támadó nagy mennyiségű SYN csomagot küld egy cél IP-címnek.
- A támadó rengeteg SYN csomagot küld, de nem válaszol a szerver SYN-ACK válaszaira
- A szerver félkész kapcsolatokban ragad
- A sok függő kapcsolat miatt elfogynak az erőforrásai a szervernek, és nem tud új kéréseket kiszolgálni.

- **Miért is veszélyesek a DoS és DDoS támadások?**

- A DoS (Denial of Service) és DDoS (Distributed Denial of Service) támadások célja, hogy túlterheljék egy rendszer erőforrásait, így az elérhetetlenné válik a valódi felhasználók számára, ami szolgáltatáskimaradást, anyagi veszteséget és hírnévkárosodást okozhat.
- Példa: Mirai botnet (zombi hálzóat) 2016 DDoS támadás.

- **XSS**

- Különböző oldalakon keresztül történő scripthívást foglal magába.
- A phishing támadásoknál használt, link alapú, nem perzisztens fajtája során magába az URL-be illesztették be az adott scriptet (pl. java script).
- Típusai:
 - **Reflected XSS** = kérés során érkezik, pl. egy manipulált URL-ben, majd azonnal visszatükröződik a weboldal válaszában
 - **Stored XSS** = a támadó kódját az adatbázisban tárolják el, így minden felhasználó, aki meglátogatja az adott oldalt, megkapja a fertőzött kódot
 - **DOM-based XSS** = a támadás a kliensoldali DOM manipulációval valósul meg, amikor a böngészőben futó JavaScript kód módosítja az oldal tartalmát

- **SQL injection**

- Egy támadási technika, amelyben rosszindulatú SQL-parancsokat juttatnak be egy alkalmazásba, hogy illetéktelenül férjenek hozzá az adatbázishoz vagy manipulálják azt.

- **Cookie poisoning**

- A cookie adatok szándékos módosítása annak érdekében, hogy a támadó előnyt szerezzen (például jogosulatlan hozzáférést vagy kedvezményeket egy weboldalon).

- **Forráskód elemzés, weboldal tükrözés**

- Olyan eljárások, ahol a weboldal forrását (HTML, JavaScript, stb.) megvizsgálják, illetve teljes weboldal-másolatot (tükrözést) készítenek a sebezhetőségek feltárása vagy offline elemzés céljából.